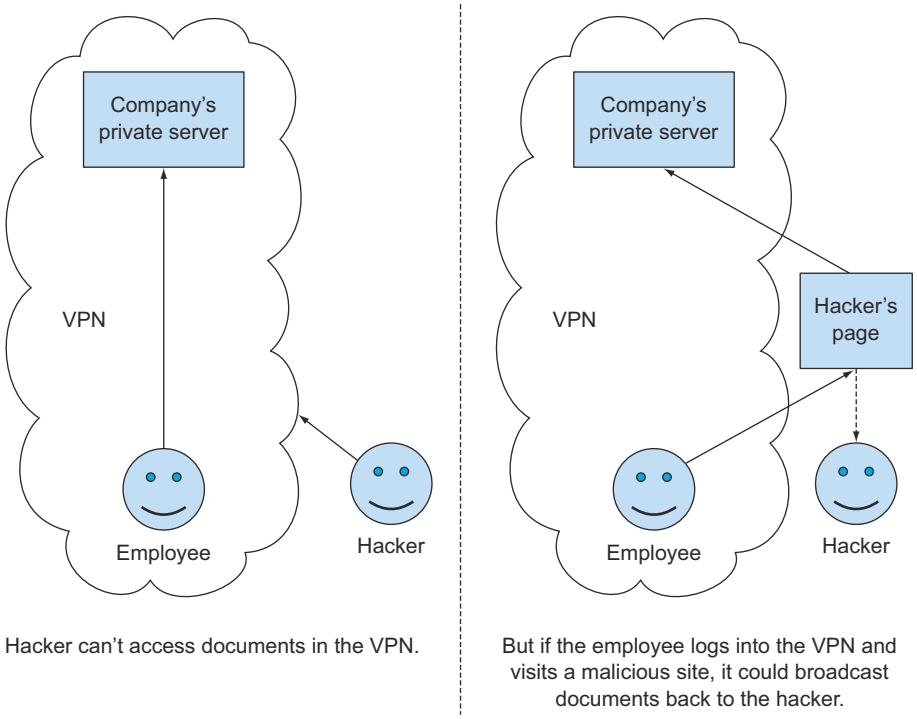


Figure 6.1 An example of how a hacker could take advantage of an `Access-Control-Allow-Origin: *` response over a VPN

able to connect to the firewall, you're able to access these documents using CORS. Now suppose some malicious hacker would like to access this document as well. He knows the URL, but he can't make a request to the document because he isn't on the firewall.

But he can create a special HTML file that makes a CORS request to grab the contents of the document, and then uploads the contents to the hacker's own server. Even though he has this specially crafted HTML file, the hacker still can't use it because he isn't connected to the firewall. But if he can somehow trick an employee to visit the web page while the employee is connected to the intranet, the CORS request will succeed and the hacker will get the contents of the document.

This example contains a lot of steps, but a determined hacker will use any tools at his disposal to get at the information he wants. If a document or API needs to be accessible to a group of users, it's best to limit the set of origins. The next section looks at how to do this.

6.3.2 *Limiting CORS requests to a set of origins*

Suppose you're in the early days of building your blogging service. While you know you'd like the mobile, tablet, and web versions of the site to be driven by the same API, you aren't yet comfortable exposing the API to external users. In this case, the `*` value